

System Development Life Cycle (SDLC)

Redwana Farbin
Lecturer,
Department of CSE, NBIU

- The system development life cycle is the overall process of developing, implementing, and retiring information systems through a multistep process from initiation, analysis, design, implementation, and maintenance to disposal.
- There are many different SDLC models and methodologies, but each generally consists of a series of defined steps or phases.
- For any SDLC model that is used, information security must be integrated into the SDLC to ensure appropriate protection for the information that the system will transmit, process, and store.

Risk management process

- Risk Management Process is the systematic process of identifying, analyzing, evaluating, controlling, and continuously monitoring risks to reduce their impact on an organization or project.
- Applying the risk management process to system development enables organizations to balance requirements for the protection of agency information and assets with the cost of security controls and mitigation strategies throughout the SDLC.
- Risk management processes identify critical assets and operations, as well as systemic vulnerabilities across the organization.

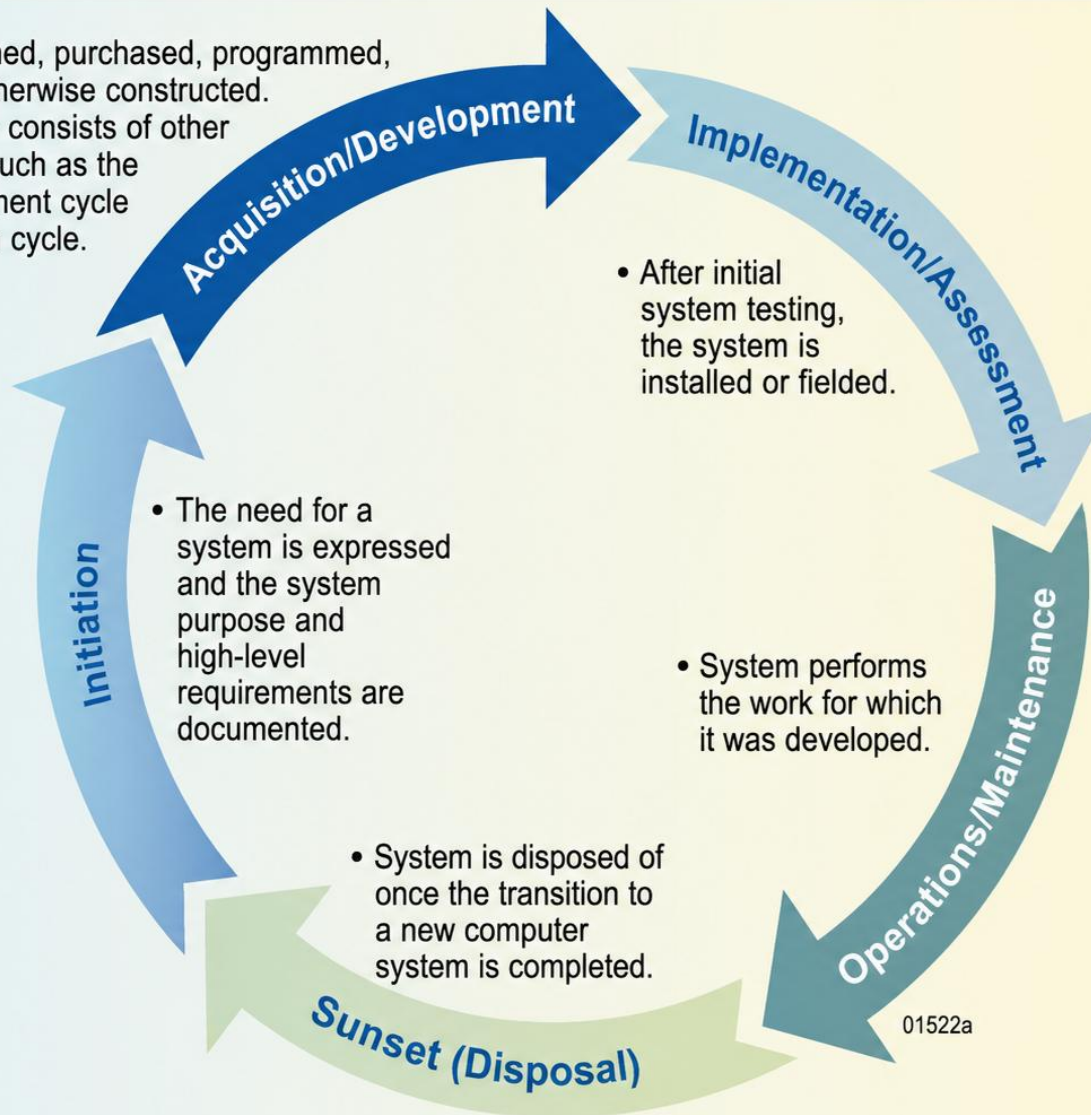
Benefits of integrating security into the SDLC

1. Early identification and mitigation of security vulnerabilities and problems with the configuration of systems, resulting in lower costs to implement security controls and mitigation of vulnerabilities.
2. Awareness of potential engineering challenges caused by mandatory security controls.
3. Identification of shared security services and reuse of security strategies and tools that will reduce development costs and improve the system's security posture through the application of proven methods and techniques.
4. Facilitation of informed executive decision making through the application of a comprehensive risk management process in a timely manner.

Benefits of integrating security into the SDLC

5. Documentation of important security decisions made during the development process to inform management about security considerations during all phases of development.
6. Improved organization and customer confidence to facilitate adoption and use of systems, and improved confidence in the continued investment in government systems.
7. Improved systems interoperability and integration that would be difficult to achieve if security is considered separately at various system levels.

- System is designed, purchased, programmed, developed, or otherwise constructed. This phase often consists of other defined cycles, such as the system development cycle of the acquisition cycle.



Initiation Phase

- During the initiation phase, the organization establishes the need for a system and documents its purpose.
- Security planning should begin in the initiation phase with the identification of key security roles to be carried out in the development of the system.
- The information to be processed, transmitted, or stored is evaluated for security requirements, and all stakeholders should have a common understanding of the security considerations. The Information System Security Officer (ISSO) should be identified as well.

Initiation Phase

- Security considerations are key to the early integration of security, and to the assurance that threats, requirements, and potential constraints in functionality and integration are considered.
- Requirements for the confidentiality, integrity, and availability of information should be assessed at this stage.
- Early planning and awareness will result in savings in costs and staff time through proper risk management planning.
- In this phase, the organization clearly defines its project goals and high-level information security requirements, as well as the enterprise security system architecture.

Development/Acquisition Phase.

- During this phase, the system is designed, purchased, programmed, developed, or otherwise constructed.
- A key security activity in this phase is conducting a risk assessment and using the results to supplement the baseline security controls.
- In addition, the organization should analyze **security requirements; perform functional and security testing; prepare initial documents for system certification and accreditation; and design the security architecture.**

Development/Acquisition Phase.

- The risk assessment enables the organization to determine the risk to operations, assets, and individuals resulting from the operation of information systems, and the processing, storage, or transmission of information.
- Another essential element is the development of security plans, which establish the security requirements for the information system, describe security controls that have been selected, and present the rationale for security categorization, how controls are implemented, and how use of systems can be restricted in high-risk situations.
- Security plans document the decisions made in the selection of controls, and are approved by authorized officials.

Development/Acquisition Phase.

- The developmental testing of the technical and security features and functions of the system ensure that they perform as intended, prior to launching the implementation and integration phase.

Implementation Phase

- In the implementation phase, the organization configures and enables system security features, tests the functionality of these features, installs or implements the system, and obtains a formal authorization to operate the system.
- Design reviews and system tests should be performed before placing the system into operation to ensure that it meets all required security specifications.
- In addition, if new controls are added to the application or the support system, additional acceptance tests of those new controls must be performed.
- This approach ensures that new controls meet security specifications and do not conflict with or invalidate existing controls. The results of the design reviews and system tests should be fully documented, updated as new reviews or tests are performed, and maintained in the organization's official records.

Operations/Maintenance Phase

- In this phase, systems and products are in place and operating, enhancements and/or modifications to the system are developed and tested, and hardware and software components are added or replaced.
- The organization should continuously monitor performance of the system to ensure that it is consistent with pre-established user and security requirements, and that needed system modifications are incorporated.

Operations/Maintenance Phase

- Configuration management (CM) and control activities should be conducted to document any proposed or actual changes in the security plan of the system.
- Information systems are in a constant state of evolution with upgrades to hardware, software, firmware, and possible modifications in the surrounding environment.
- Documenting information system changes and assessing the potential impact of these changes on the security of a system are essential activities to assure continuous monitoring, and prevent lapses in the system security accreditation.

Disposal Phase

- In this phase, plans are developed for discarding system information, hardware, and software and making the transition to a new system.
- The information, hardware, and software may be moved to another system, archived, discarded, or destroyed.
- If performed improperly, the disposal phase can result in the unauthorized disclosure of sensitive data.
- When archiving information, organizations should consider the need for and the methods for future retrieval.

Disposal Phase

- The disposal activities ensure the orderly termination of the system and preserve the vital information about the system so that some or all of the information may be reactivated in the future, if necessary.
- Particular emphasis is given to proper preservation of the data processed by the system so that the data is effectively migrated to another system or archived in accordance with applicable records management regulations and policies for potential future access.
- The removal of information from a storage medium, such as a hard disk or tape, should be done in accordance with the organization's security requirements.